

Manual 46 — Fundamentos Universales de Gobierno de IA

****Estado:**** DESARROLLO CONTROLADO

****Idioma:**** Español latinoamericano (`es-419`)

****Alcance:**** Base universal y consciente de las jurisdicciones para el gobierno empresarial de IA.

Propósito

Este manual establece una base universal para gobernar sistemas de inteligencia artificial sin depender de un empleador, una jurisdicción, un regulador, un proveedor, una familia de modelos o una arquitectura tecnológica específica. Aplica a IA predictiva, aprendizaje automático, IA generativa, modelos fundacionales, sistemas RAG, IA incorporada y sistemas agénticos.

El objetivo no es impedir el uso de IA. El objetivo es permitir una adopción demostrablemente segura, lícita, controlada, útil y responsable.

Columna vertebral universal de gobierno

****Responsabilidad → Inventario → Clasificación → Evaluación de riesgos e impactos → Gobierno de datos → Seguridad → Privacidad → Supervisión humana → Transparencia → Pruebas y validación → Documentación → Aprobación → Despliegue → Monitoreo → Gestión de incidentes y cambios → Gobierno de terceros → Evidencia y auditoría → Retiro → Mejora continua****

Principios fundamentales

1. Toda iniciativa de IA debe tener un responsable de negocio y un responsable técnico claramente identificados.
2. La intensidad del gobierno debe ser proporcional al riesgo, impacto, autonomía, criticidad, sensibilidad de los datos y exposición legal.
3. Se gobierna el sistema completo, no solamente el modelo: datos, instrucciones, RAG, herramientas, APIs, agentes, personas, proveedores e infraestructura forman parte del alcance.
4. La gobernanza comienza antes de producción mediante admisión, inventario, clasificación, evaluación y aprobación.
5. La supervisión humana debe ser significativa: competencia, información, tiempo, autoridad y capacidad real de intervenir.
6. Seguridad y privacidad son componentes nativos del gobierno de IA.
7. Las decisiones y controles deben producir evidencia verificable.
8. El uso de proveedores externos no elimina la responsabilidad de la organización adoptante.
9. El monitoreo debe detectar cambios de desempeño, riesgo, modelo, proveedor, datos, herramientas, permisos y obligaciones regulatorias.
10. El gobierno debe habilitar la innovación responsable sin imponer controles desproporcionados a usos de bajo riesgo.

Módulo 1 — Mandato y modelo operativo

Definir patrocinio ejecutivo, alcance, apetito de riesgo, autoridad de decisión, escalamiento y separación entre primera, segunda y tercera línea.

****Evidencia:**** estatuto de gobierno de IA, políticas, matriz de decisiones, términos de referencia del comité y vínculo con el apetito de riesgo.

Módulo 2 — Inventario de IA

El inventario es el sistema de registro para la gobernanza. Debe incluir identificador, propósito, propietarios, modelo/proveedor/versión, usuarios, poblaciones afectadas, datos, terceros, geografía, nivel de riesgo, autonomía, supervisión humana, validación, aprobación, monitoreo, cambios, incidentes y retiro.

Módulo 3 — Clasificación de riesgo, impacto y autonomía

Evaluar impacto sobre personas y derechos, salud y seguridad, criticidad empresarial, exposición financiera, sensibilidad de datos, privilegios de ciberseguridad, autonomía, reversibilidad, escala, uso externo/interno, clasificación regulatoria, concentración y necesidad de explicabilidad o impugnación.

La clasificación determina profundidad de evaluación, revisores obligatorios, independencia de validación, autoridad de aprobación y frecuencia de monitoreo.

Módulo 4 — Evaluación de riesgos e impactos

Cubrir riesgos estratégicos, regulatorios, de derechos humanos, seguridad física, desempeño del modelo, calidad/procedencia de datos, privacidad, ciberseguridad, abuso, sesgo, transparencia, propiedad intelectual, terceros, resiliencia, autonomía, fraude y reputación.

Usar la estructura:

****Escenario → Causa → Impacto → Riesgo inherente → Control → Riesgo residual → Responsable → Decisión****

Módulo 5 — Gobierno de datos y conocimiento

Controlar linaje, procedencia, propósito autorizado, calidad, minimización, datos sensibles, retención, separación de entrenamiento/evaluación cuando corresponda, autorización de corpus RAG, permisos de recuperación, corrección, eliminación y términos de uso de datos de proveedores.

Prompts, contexto, almacenes vectoriales, índices, embeddings y conjuntos de ajuste pueden constituir activos de información gobernados.

Módulo 6 — Seguridad de IA

Evaluar endpoints de modelos, identidades, APIs, secretos, pipelines, prompts, instrucciones de sistema, recuperación, herramientas, plugins, permisos de agentes, dependencias y telemetría.

Controles clave: mínimo privilegio, protección de credenciales, validación de entradas/salidas, resistencia a inyección de prompts, prevención de exfiltración, integridad de dependencias, detección de ataques, contención y recuperación.

Módulo 7 — Supervisión humana significativa

Definir qué decisiones requieren revisión humana, quién puede aprobar o anular, qué información recibe el revisor, tiempos de respuesta, umbrales de escalamiento, capacidad de detener o suspender y registro de intervenciones.

Un revisor sin tiempo o autoridad real no constituye un control efectivo.

Módulo 8 — Pruebas, evaluación, verificación y validación

Evaluar desempeño previsto, robustez, casos límite, abuso, seguridad, privacidad, equidad cuando corresponda, explicabilidad, factores humanos, recuperación de fallas, factualidad/confabulación en GenAI, calidad de recuperación RAG y límites de acciones agénticas.

La independencia de validación debe aumentar con la materialidad.

Módulo 9 — Puertas de aprobación del ciclo de vida

****Admisión → Inventario → Clasificación → Evaluación → Diseño/Adquisición → Validación → Aprobación → Despliegue → Monitoreo → Cambio/Revalidación → Retiro****

Decisiones permitidas: aprobar, aprobar con condiciones, rechazar, diferir, excepción temporal, suspender o retirar.

Módulo 10 — Gobierno de terceros

Evaluar gobierno del proveedor, seguridad, privacidad, uso de datos, limitaciones del modelo, subprocesadores, procesamiento geográfico, cambios, incidentes, evidencia de aseguramiento, continuidad, obligaciones contractuales, salida y portabilidad.

Módulo 11 — IA generativa

Agregar controles para confabulación, inyección de prompts, fuga de información, gobierno RAG, validación de salidas, procedencia y etiquetado de contenido cuando aplique, propiedad intelectual, red teaming, guardrails y comportamiento seguro de respaldo.

Módulo 12 — IA agéntica

Gobernar acciones, no solamente contenido. Controlar identidad del agente, propósito acotado, autenticación, autorización, mínimo privilegio, listas permitidas de herramientas/APIs, aislamiento de credenciales, límites de transacción/recursos, aprobaciones humanas, segregación de funciones, procedencia de acciones, monitoreo en ejecución, desactivación de emergencia, delegación entre agentes y revalidación tras cambios.

Módulo 13 — Monitoreo continuo

Monitorear deriva, errores, tasas de intervención humana, resultados dañinos, eventos de seguridad y privacidad, uso no autorizado de herramientas, excepciones, hallazgos abiertos, cambios de modelo/proveedor y revalidaciones vencidas.

Cada indicador debe tener responsable, umbral, frecuencia, fuente de evidencia y respuesta definida.

Módulo 14 — Gestión de incidentes y cambios

Ciclo de incidente:

****Detectar → Contener → Preservar evidencia → Evaluar impacto → Escalar/Notificar → Remediar → Validar → Aprender****

Cambios materiales incluyen modelo, versión, proveedor, instrucciones, datos, fuentes RAG, herramientas, permisos, población usuaria, geografía, propósito o aumento de autonomía.

Módulo 15 — Evidencia y aseguramiento

Cadena universal:

****Requisito o Riesgo → Objetivo de control → Actividad de control → Responsable → Frecuencia/Disparador → Evidencia → Procedimiento de prueba → Excepción → Remediación → Decisión de riesgo residual****

Niveles de aseguramiento: autoevaluación de primera línea, desafío/pruebas de segunda línea, validación independiente, auditoría interna y aseguramiento externo cuando corresponda.

Módulo 16 — Gobierno ejecutivo y de junta directiva

Reportar inventario por nivel de riesgo, sistemas de alto impacto, estado de validación/aprobación, aceptaciones de riesgo residual, excepciones, hallazgos críticos, incidentes, concentración de proveedores, exposición regulatoria y KRIs frente al apetito de riesgo.

Escenarios prácticos

1. Asistente GenAI interno

Evaluar acceso, confidencialidad, datos, RAG, outputs, proveedor, monitoreo y uso aceptable.

2. IA orientada al cliente

Evaluar impacto, explicabilidad, posibilidad de impugnación, validación, supervisión y transparencia.

3. Selección de personal con IA

Evaluar proveedor, procedencia, equidad, supervisión, aplicabilidad jurídica y evidencia.

4. RAG sobre información sensible

Evaluar autorización de repositorios, permisos por documento, vector stores, actualidad, fuga de datos e inyección indirecta.

5. Agente autónomo de servicio

Evaluar identidad, permisos, herramientas, límites, aprobaciones humanas, segregación, logs, monitoreo y parada de emergencia.

6. Asistente de programación

Evaluar confidencialidad de código, dependencias, secretos, licencias, revisión y pruebas de seguridad.

7. Automatización de bajo impacto

Aplicar proporcionalidad sin controles excesivos.

8. Cambio material de modelo de proveedor

Exigir notificación, pruebas de regresión, reevaluación, rollback y revalidación.

9. Incidente de IA

Contener, preservar evidencia, evaluar impacto, notificar cuando corresponda, remediar y revalidar.

10. Pregunta de junta directiva

Responder dónde existe mayor riesgo de IA y cómo se demuestra que los controles funcionan.

Dominios mínimos de control

- GOV-01 Responsabilidad de IA.
- INV-01 Integridad del inventario.
- CLS-01 Clasificación de riesgo/autonomía.
- RSK-01 Evaluación de riesgos e impactos.
- DAT-01 Gobierno de datos/conocimiento.
- SEC-01 Revisión de seguridad de IA.
- PRV-01 Evaluación de privacidad.
- HUM-01 Supervisión humana significativa.
- VAL-01 Pruebas y validación.
- APP-01 Aprobación de despliegue.
- TPR-01 Gobierno de terceros.
- MON-01 Monitoreo continuo.
- CHG-01 Cambios materiales y revalidación.
- INC-01 Gestión de incidentes de IA.
- AUD-01 Evidencia y aseguramiento.
- RET-01 Retiro y desmantelamiento.

Criterio de finalización

La persona que complete el Manual 46 debe poder tomar cualquier caso de uso de IA y construir una cadena trazable desde propósito y propiedad hasta clasificación, riesgos, controles, evidencia, aprobación, monitoreo, incidentes, cambios y decisión de riesgo residual.